

Expert Systems in Information Security: A Comprehensive Exploration of Awareness Strategies Against Social Engineering Attacks

Waldson Rodrigues Cardoso¹, Admilson de Ribamar Lima Ribeiro² and João Marco Cardoso da Silva³

¹ Computing Department, Federal University of Sergipe, UFS São Cristóvão, Brazil
`waldson.cardoso@comp.ufs.br`

² Computing Department, Federal University of Sergipe, UFS São Cristóvão, Brazil,
`admilson@comp.ufs.br`

³ Department of Informatics, University of Minho Braga, Portugal,
`joaomarco@di.uminho.pt`

Abstract. This article delves into the pivotal role of expert systems in bolstering information security, with a specific emphasis on their effectiveness in awareness and training programs aimed at thwarting social engineering attacks. Employing a snowball methodology, the research expands upon seminal works, highlighting the intersection between expert systems and cybersecurity. The study identifies a gap in current understanding and aims to contribute valuable insights to the field. By analyzing five key articles as seeds, the research explores the landscape of expert systems in information security, emphasizing their potential impact on cultivating robust defenses against evolving cyber threats.

Keywords: Expert Systems, Information Security, Cybersecurity Education, Social Engineering, Snowball Methodology

1 Introduction

In today's dynamic and ever-changing digital landscape, safeguarding sensitive information against cyber threats has become an undeniable priority. Among the various challenges faced in the field of information security, social engineering attacks emerge as a particularly insidious threat, exploiting the human factor to compromise digital defenses. In this challenging context, expert systems, tools that replicate the decision-making capability of human experts, stand out in the field of artificial intelligence.

These systems are meticulously designed to address complex challenges, operating based on logical rules grounded in the "if-then" structure. Notably applied in educational decision-making, their utility extends, as demonstrated by Hwang et al. [1], to awareness and training in cybersecurity, enabling an effective educational approach.

As we delve into this topic, the article will unfold in a structured manner. Initially, we will provide a brief introduction to social engineering and real-world examples of attacks, offering the essential context necessary for the subsequent analysis of the pivotal role played by expert systems. Following that, we will elucidate the snowball methodology, adopted in our research, providing insights into the approach employed for the collection and analysis of relevant literature. Subsequent sections will delve into the results from seminal works, examining the identified seeds and their contributions to understanding the intersection between expert systems and information security.

Furthermore, we will dedicate a section to the discussion, where we will deepen the analyses conducted and explore deeper connections between the findings. Finally, in the conclusion, we will summarize key findings, highlight practical implications, and point towards directions for future research. Through this structured approach, our aim is to provide a comprehensive view of the strategies adopted by expert systems to strengthen awareness and training against sophisticated social engineering attacks.

2 Social Engineering

Social engineering, as elucidated by [2], involves the manipulation, deception, and influence of individuals within an organization to comply with specific requests, ranging from disclosing sensitive information to executing tasks beneficial to the attacker. This includes simple interactions like phone calls and more complex strategies such as guiding the target to visit a website exploiting technical vulnerabilities to assume control of their computer.

In the realm of Information and Communication Technologies (ICT) security, [3] provides context for social engineering, addressing actions aimed at obtaining and exploring valuable information, including confidential data from organizations and computer systems, all by exploiting people's trust.

Defined by [4], social engineering comprises a set of techniques to manipulate people, leading them to perform actions or disclose information they wouldn't normally divulge.

Underscoring the importance of implementing and monitoring security mechanisms, coupled with specific precautions regarding electronic waste to mitigate social engineering threats, [5] emphasize the necessity of such measures. Additionally, user awareness, as highlighted by [6], is fundamental for businesses. Implementing appropriate strategies for the safe use of online social networks is crucial, aiming to prevent falling victim to social engineering attacks.

2.1 Social Engineering Attacks

Below are real examples of social engineering attacks, illustrating their diversity and sophistication:

1. Ubiquiti Networks in Hong Kong experienced a loss of approximately USD 40 million in a phishing attack, wherein attackers compromised the email account of a high-ranking employee, soliciting fraudulent payments [7].

2. During the 2016 US presidential election, hackers utilized spear phishing to create a fake email on Gmail, prompting users to change passwords. The subsequent email leak influenced the election result, favoring Donald Trump over Hillary Clinton [8] .
3. Cabarrus County in the United States fell victim to a social engineering attack resulting in a loss of USD 1.7 million. Hackers employed malicious emails, posing as suppliers, to request payments to a new bank account [9] .
4. Toyota Boshoku Corporation incurred a loss of approximately USD 37 million in a social engineering attack in Japan. Attackers persuaded a financial executive to alter bank information for an electronic transfer [10].
5. A phishing scam led to a loss of approximately USD 400,000, where a cybercriminal posed as an assistant to a victim, soliciting payment related to real estate investments [11].
6. An 18-year-old hacker gained access to the internal network at Uber. This was a direct result of a phishing attack, and the victim, who was an employee, approved an MFA request. The attacker then looked deeper into Uber's internal systems and found a PowerShell script with admin credentials that gave him access to AWS, OneLogin, and GSuite, to name a few [12].
7. This hack was supposedly done by the same hacker who did the Uber hack. The hacker used social engineering to get into their Slack server by tricking one of the employees. He was able to grab the source code for the games GTA V and GTA VI (unreleased) and also released some of the screen recordings of the game, which seem to be a debug version [12].

These examples underscore the need for robust awareness and security strategies to effectively mitigate the diverse and sophisticated threats posed by social engineering.

Understanding the diversity and sophistication of social engineering attacks highlights the need for effective awareness and security strategies. In this context, we will now delve into the snowball methodology, a crucial approach we employ to deepen our understanding of these challenges and opportunities.

3 Snowball: Strategy

Supplementary research was imperative to elucidate the intricacies explored in this work. To achieve this, we employed the snowball methodology, a non-probabilistic sampling technique. As delineated by [13], this approach relies on pre-established inclusion criteria, offering targeted insights rather than encompassing the entire population in the sampling process.

The methodology unfolds through specific steps: the identification of pivotal documents or seeds, which conventionally mark the inception of the research line; these seeds, in turn, point to additional contributors, and the process iterates. Saturation is achieved by the repetitive emergence of themes, signaling the point where new indications cease to yield substantially novel insights or a satisfactory quantity of samples [14].

New contributors, even if indicated, undergo scrutiny to ensure alignment with defined characteristics. The snowball methodology serves exploratory purposes, aiming "[...] to understand a theme, test the feasibility of conducting a broader study, and develop the methods to be used in all subsequent studies or phases" [14].

The exploratory methodology emerges as a strategic approach to bridge the identified gap, specifically investigating how expert systems can seamlessly integrate into the context of awareness and training against social engineering threats. This endeavor aspires to make a substantial contribution to understanding the intersection between expert systems and information security practices, fostering a more holistic and informed perspective on digital protection strategies.

For this review, a search was conducted on Google Scholar from January 2 to 20, 2023, utilizing the following search terms: ("expert system") AND ("information security" OR "cybersecurity") AND ("social engineering") AND ("education" OR "awareness" OR "training"). Following predefined criteria, five works were selected as seeds. These seeds led to indications, denominated as references. The chosen works as seeds underwent rigorous selection based on the following criteria:

- Inclusion among the top 10 results returned by Google Scholar, with the condition that the article is accessible;
- Publication between 2013 and 2023, prioritizing recent works for updated results and information;
- References of the seeds adhered to the criteria of relevance to Expert Systems and Information Security, excluding books or articles from websites and blogs;

While the selected initial articles provided valuable insights into the broader landscape of expert systems and information security, it is noteworthy to mention that they did not generate additional seeds. This limitation is attributed to the thematic constraints and the specified time frame for this research (2013 to 2023). Consequently, the absence of derived seeds from these initial articles influenced the scope and breadth of the literature review, particularly in certain thematic areas. These constraints are acknowledged as inherent aspects of the research process and are explicated to provide transparency regarding the methodology's intricacies.

With the snowball methodology laying the groundwork for our investigation, we now turn our attention to the outcomes derived from the systematic review. By applying this refined methodological approach to the selected works, we can discern significant patterns and glean valuable insights into the role of expert systems in information security. Let's delve into how each seed article contributes to a broader understanding of the intersection between expert systems and digital security threats.

4 Results

In this section, we present the outcomes of the snowball review, highlighting key findings from the selected seed articles.

4.1 Summary Introduction to Results

Before delving into the specifics of each seed article, let's provide a brief overview of the main insights obtained from the selected literature.

4.2 Overview of Seed Articles

Table 1 outlines the seed articles chosen for the snowball review, each contributing unique perspectives to the intersection of expert systems and information security.

Table 1: Snowball Review Seeds

ID	Title	Reference
S1	CSAAES: An expert system for awareness of cyber security attacks	[15]
S2	Cyber attacks based on social engineering in Kenya	[16]
S3	Development of a consultative knowledge-based expert system to identify and mitigate unintentional internal threats in Ethiopian financial institutions	[17]
S4	An Effective Cybersecurity Awareness Training Model: First Defense of an Organizational Security Strategy	[18]
S5	Expert system with fuzzy logic for the protection of scientific information resources	[19]

S-1: *CSAAES: An expert system for awareness of cyber security attacks* [15] The first seed article, authored by [15], emphasizes the necessity for cyber attack protection in the context of widespread internet usage and information exposure. The presented expert system, CSAAES, focuses on raising user awareness about various attack types, symptoms, and countermeasures. While the seeds referenced by this article fall outside our specified time range, the work offers valuable insights into cyber attack awareness.

S-2: *Cyber attacks based on social engineering in Kenya* [16] Addressing cyber attacks in Kenya, the second seed by [16] explores social engineering techniques employed by cybercriminals. The article proposes an expert system-based awareness model to instill a secure mindset in users, stressing the importance of future work for model implementation and validation.

S-3: *Development of a consultative knowledge-based expert system to identify and mitigate unintentional internal threats in Ethiopian financial institutions* [17] The third seed, authored by [17], focuses on security in financial institutions, highlighting the challenge of detecting unintentional internal threats. The article proposes a knowledge-based expert system as a practical solution to mitigate such threats in Ethiopian financial institutions.

S-4: *An Effective Cybersecurity Awareness Training Model: First Defense of an Organizational Security Strategy* [18] The fourth seed, authored by [18], emphasizes the importance of Security Education, Training, and Awareness (SETA) in organizational security strategies. The proposed model, viCyber, incorporates an expert system to develop cybersecurity curricula and enhance user understanding through real-time feedback.

S-5: *Expert system with fuzzy logic for the protection of scientific information resources* [19] The fifth seed by [19] delves into using expert systems with fuzzy logic to protect information resources in scientific libraries and corporate networks. The article underscores the benefits of expert systems in conjunction with user awareness to enhance information security.

Table 2: Comparison of articles related to the conducted research

ID	Methodology	Key Findings	Contributions
S-1	Survey on cyber security awareness programs; Integration of expert systems	Identified awareness gap; Proposed CSAAES expert system	Insights into expert systems for cyber security awareness
S-2	Case study on cyber attacks in Kenya; Analysis of social engineering techniques	Revealed social engineering tactics; Proposed expert system model	Specific approach to address social engineering threats
S-3	Exploratory applied research with quantitative approach; Rule-based knowledge representation	Effectiveness in detecting internal threats	Practical solution for internal security in financial institutions
S-4	Qualitative research using the Technology Acceptance Model (TAM); Examination of AI-based security awareness training programs	Innovative approach to cyber security education and training; Emphasized importance of SETA; Introduced viCyber model	Contribution to AI-enabled security awareness training
S-5	Analysis of the state of development of research on protecting scientific and educational databases in libraries; Application of fuzzy logic methods	Benefits of expert systems with fuzzy logic	Insights into the potential of fuzzy logic in information security

5 Discussion

The synthesis of findings from the selected seed articles sheds light on the intricate relationship between expert systems and information security, with a specific focus on awareness and training against social engineering threats. Here, we distill the key insights derived from our review:

CSAAES: An expert system for awareness of cyber security attacks [15]: Rani and Goel's work underscores the critical need for cyber attack awareness in the age of widespread internet use. The CSAAES expert system serves as a noteworthy tool for raising user awareness, emphasizing the importance of understanding various attack types and implementing effective countermeasures.

Cyber attacks based on social engineering in Kenya [16]: Obuhuma and Zivuku's exploration of social engineering techniques in the Kenyan context illuminates the vulnerabilities arising from a lack of user awareness. The proposed expert system-based awareness model stands out as a potential strategy to foster a secure mindset and combat social engineering attacks.

Development of a consultative knowledge-based expert system to identify and mitigate unintentional internal threats in Ethiopian financial institutions [17]: Adane's focus on internal threats within financial institutions highlights the challenges posed by unintentional employee actions. The proposed knowledge-based expert system offers a practical approach to identify and mitigate these threats, providing valuable insights for enhancing internal security measures.

An Effective Cybersecurity Awareness Training Model: First Defense of an Organizational Security Strategy [18]: Dash and Ansari's emphasis on Security Education, Training, and Awareness (SETA) aligns with the growing recognition of human factors in organizational security. The viCyber model, incorporating an expert system, presents an innovative approach to developing cybersecurity curricula and enhancing user understanding, showcasing the potential of expert systems in educational contexts.

Expert system with fuzzy logic for the protection of scientific information resources [19]: Normatov and Rakhmatullaev's exploration of expert systems with fuzzy logic for information resource protection emphasizes the synergy between technology and user awareness. The integration of expert systems, coupled with user education, emerges as a multifaceted strategy to enhance information security in scientific libraries and corporate networks.

In essence, these articles collectively reinforce the pivotal role of expert systems in addressing diverse facets of cybersecurity challenges. The integration of technological solutions with user education emerges as a holistic approach, acknowledging the human factor in cybersecurity. This synthesis provides a comprehensive view, setting the stage for further research and practical implementations in the dynamic field of expert systems and information security.

This synthesis not only consolidates the current understanding but also provides a comprehensive and panoramic view of the subject, thereby setting the stage for further exploration through research endeavors and practical implementations in the dynamic field of expert systems and information security.

6 Conclusion

In conclusion, the snowball review of expert systems in the context of information security, particularly focusing on awareness and training against social engineering threats, reveals a rich landscape of innovative approaches and practical solutions. The selected seed articles collectively emphasize the pivotal role of expert systems in addressing various facets of cybersecurity challenges. From raising awareness about cyber attacks to mitigating internal threats and developing effective cybersecurity training models, these articles provide valuable insights into the diverse applications of expert systems.

The synthesis of findings underscores the need for a holistic approach that combines technological solutions, such as expert systems, with user education and awareness. The effectiveness of expert systems is not only in their technical capabilities but also in their integration into broader strategies that consider the human factor in cybersecurity. The presented seed articles serve as a foundation for further research and exploration in the dynamic and evolving field of expert systems and information security.

For future research, it is essential to delve deeper into implementing the proposed expert systems, assessing their real-world effectiveness, and exploring advancements in integrating artificial intelligence with human-centric approaches for improved cybersecurity. This involves thorough evaluations of the practical deployment of expert systems, gauging their impact, and investigating innovative strategies for enhancing the collaboration between AI and human expertise. In summary, further research in these areas will contribute to refining cybersecurity measures for greater effectiveness and adaptability.

7 Recommendations for Future Research

Based on the insights gained from the snowball review, several recommendations for future research emerge:

1. **Implementation and Validation Studies:** Conduct comprehensive studies to implement and validate the proposed expert systems in real-world settings. Assess their effectiveness in diverse organizational contexts to understand their practical implications.
2. **Human-Centric Approaches:** Explore further the integration of human-centric approaches in conjunction with expert systems. Investigate how user education and awareness programs can be seamlessly integrated with expert systems to enhance overall cybersecurity resilience.
3. **Continuous Adaptation:** Given the evolving nature of cybersecurity threats, research should focus on developing expert systems that can adapt and evolve in response to emerging threats. This could involve the integration of machine learning algorithms for continuous learning and improvement.
4. **Cross-Domain Applications:** Investigate the potential cross-domain applications of expert systems in information security. Explore how the principles and frameworks developed in one domain, such as financial institutions, can be adapted and applied in other sectors.

5. **User Experience and Acceptance:** Examine the user experience and acceptance of expert systems in different organizational settings. Understand the factors that influence user trust and engagement with these systems, ultimately impacting their effectiveness.

By addressing these recommendations, future research can contribute to the ongoing advancement of expert systems in information security, fostering a more resilient and adaptive cybersecurity landscape.

8 Acknowledgments

Grateful for our supervisor's invaluable assistance, we extend heartfelt thanks to the Federal University of Sergipe, Brazil, and CAPES (PDPG – Strategic Partnerships in States III) for their unwavering support in completing this research. We also appreciate the contributions of the seed article authors and acknowledge the researchers and practitioners whose work forms the foundation of this snowball review.

References

1. Hijji, M., Alam, G.: Cybersecurity Awareness and Training (CAT) Framework for Remote Working Employees. *Sensors (Basel)*, **22**(22), 8663 (2022). <https://www.mdpi.com/1424-8220/22/22/8663>
2. Mitnick, K. D., Simon, W. L.: *The Art of Deception: Controlling the Human Element of Security*. John Wiley & Sons (2003).
3. Hadnagy, C.: *Social Engineering: The Art of Human Hacking*. John Wiley & Sons (2010).
4. Coelho, C. F., Rasma, E. T., Morales, G.: Social engineering: a threat to the information society. *Exatas & Engenharias, Higher Education Institutes of Censa*, **3**(05) (2013).
5. Aramuni, J. P. C., Maia, L. C.: The impact of social engineering on information security: a management-oriented approach. *AtoZ: New Practices in Information and Knowledge*, **7**(1), 31–37 (2020).
6. Silva, N. B. X., Araújo, W. J. d., Azevedo, P. M. d.: Social engineering in online social networks: a case study on the exposure of personal information and the need for information security strategies. *Ibero-American Journal of Information Science*, **6**(2) (2013).
7. Pinzón, J. J. S. et al.: Social engineering, the before and now of a global problem. *National Open and Distance University UNAD*, 2015.
8. Honório, T. J.: The use of cyberattacks in elections and international relations. *Mural Internacional*, **9**(1), 85–98 (2018).
9. Júnior, J. V. C.: Threat analysis environment for threat intelligence generation using open sources. 2018.
10. Paschoal, D. A. C., Pereira, G. F.: Information security in Industry 4.0: NIST framework. Faculdade de Tecnologia de Americana, 2019.
11. Dantas, A. R. P.: CYRM: Cyber Range to support the teaching of defense for students in the Information Security discipline. 2022.

12. Nair, A. S. V., Achary, R.: Social Engineering Defender (SE.Def): Human Emotion Factor Based Classification and Defense against Social Engineering Attacks. *2023 International Conference on Artificial Intelligence and Applications (ICAIA) Alliance Technology Conference (ATCON-1)*, Bangalore, India, 2023, pp. 1-5, doi: 10.1109/ICAIA57370.2023.10169678.
13. Bickman, L., Rog, D.J.: *The SAGE handbook of applied social research methods*. Sage publications (2008).
14. Vinuto, J.: A amostragem em bola de neve na pesquisa qualitativa: um debate em aberto. *Temáticas*, **22**(44), 203–220 (2014).
15. Rani, C., Goel, S.: CSAAES: An expert system for cyber security attack awareness. *International Conference on Computing, Communication Automation* (2015), 242–245. <https://doi.org/10.1109/CCAA.2015.7148381>
16. Obuhuma, J., Zivuku, S.: Social Engineering Based Cyber-Attacks in Kenya. *2020 IST-Africa Conference (IST-Africa)* (2020), 1-9.
17. Adane, K.: Development of Advisory Knowledge-Based Expert System to Identify and Mitigate Unintentional Insider Threats in Financial Institutions of Ethiopia. *IUP Journal of Computer Sciences* **14**(3), 7–23 (2020). IUP Publications.
18. Dash, B., Ansari, M. F. (2022). An Effective Cybersecurity Awareness Training Model: First Defense of an Organizational Security Strategy. *Year*.
19. Normatov, S., Rakhmatullaev, M.: Expert system with Fuzzy logic for protecting Scientific Information Resources. *2020 International Conference on Information Science and Communications Technologies (ICISCT)*, 1-4 (2020). <https://doi.org/10.1109/ICISCT50599.2020.9351498>